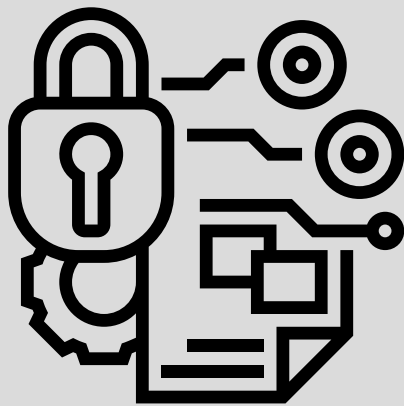


Vulnerability Assessment Report

Security Assessment of OWASP Juice Shop



👤 Prepared By: AARISHA R

📅 Date: 11/05/2026

🔧 Tools Used:

OWASP ZAP

Browser DevTools

Executive Summary

Objective

This assessment was conducted to identify common web application vulnerabilities in the OWASP Juice Shop application.

Scope

- Target: OWASP Juice Shop
- Assessment Type: Passive Vulnerability Assessment
- Testing Tool: OWASP ZAP
-

Summary of Findings

 Risk Level	 Count
High	0
Medium	2
Low	2

Key Findings

- Cookie without HttpOnly Flag
- Missing Anti-clickjacking Header
- CSP Header Not Set
- X-Content-Type-Options Header Missing

Methodology

Steps Performed

1. Application Exploration
2. Passive Security Scanning
3. Vulnerability Identification
4. Risk Classification
5. Documentation

Tools Used

Tool	Purpose
OWASP ZAP	Vulnerability scanning
Browser	Manual interaction

Finding #1

Cookie No HttpOnly Flag

! Risk Level

Medium

Description

The application sets cookies without enabling the HttpOnly attribute.

Impact

Attackers may steal session cookies through malicious scripts.

Evidence

The screenshot shows a web browser interface with a list of cookies on the left and a detailed view of a specific cookie on the right. The cookie is named 'Cookie No HttpOnly Flag' and is set by 'https://www.bing.com/api/shopping/v1/user/shoppingsettings'. The cookie's attributes are: URL: https://www.bing.com/api/shopping/v1/user/shoppingsettings, Risk: Low, Confidence: Medium, Parameter: MUJD, Attack: Evidence: Set-Cookie: MUJD, CWE ID: 1004, WASC ID: 13, Source: Passive (10010 - Cookie No HttpOnly Flag). The description states: 'A cookie has been set without the HttpOnly flag, which means that the cookie can be accessed by JavaScript. If a malicious script can be run on this page then the cookie will be accessible and can be transmitted to another site. If this is a session cookie then session hijacking may be possible.'

Recommendation

Enable the HttpOnly flag for all sensitive cookies.

Finding #2

Missing Anti-clickjacking Header

⚠ Risk Level

● Medium

Description

The application does not implement anti-clickjacking protection headers.

Impact

Attackers may trick users into clicking hidden malicious elements.

Evidence

The screenshot displays the Burp Suite application interface. On the left, the 'Alerts' tab is active, showing a list of alerts. The alert 'Missing Anti-clickjacking Header' is selected and highlighted in blue. The main panel on the right provides details for this alert:

- URL:** https://juice-shop.herokuapp.com/socket.io/?EIO=4&transport=polling&t=PuLUL8a&sid=40uIQnylpQqDouc4AAEO
- Risk:** Medium
- Confidence:** Medium
- Parameter:** x-frame-options
- Attack:**
- Evidence:**
- CWE ID:** 1021
- WASC ID:** 15
- Source:** Passive (10020 - Anti-clickjacking Header)
- Alert Reference:** 10020-1
- Input Vector:**
- Description:** The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.

The bottom status bar shows 'Current Status' with various icons and 'Main Proxy: localhost:8080'.

Recommendation

Implement the X-Frame-Options header.

Finding #3

Content Security Policy (CSP) Header Not Set

! Risk Level

● Low

Description

The website does not define a Content Security Policy.

Impact

Malicious scripts may execute within the browser.

Evidence

The screenshot displays the ZAP (Zed Attack Proxy) interface. The top menu bar includes File, Edit, View, Analyse, Report, Tools, Import, Export, Online, and Help. The main window is divided into several panes. On the left, the 'Sites' pane lists various websites, including 'https://paywallet-dn-prod.azureedge.net', 'https://accounts.google.com', 'https://editor.svc.cloud.microsoft', 'https://edge-consumer-static.azureedge.net', 'https://juice-shop.herokuapp.com', and 'https://data-edge.smartscreen.microsoft.com'. The 'History' pane shows a list of visited URLs. The 'Alerts' pane on the right displays a list of security alerts, with 'Content Security Policy (CSP) Header Not Set' highlighted. The 'Output' pane shows the details of the selected alert, including the URL 'https://juice-shop.herokuapp.com/', the risk level 'Medium', and the confidence 'High'. The 'Description' pane provides a detailed explanation of the alert, stating that CSP is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. The 'Solution' pane suggests ensuring that the web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header. The 'Reference' pane lists relevant references for the alert.

Recommendation

Configure a strong CSP header.

Finding #4

X-Content-Type-Options Header Missing

! Risk Level

● Low

Description

The application does not prevent MIME-type sniffing.

Impact

Browsers may incorrectly interpret malicious files.

Evidence

The screenshot displays the Burp Suite interface. On the left, the 'Alerts' tab is active, showing a list of detected issues. The issue 'X-Content-Type-Options Header Missing (Systemic)' is selected and highlighted in blue. The main panel on the right provides detailed information about this specific finding:

- URL:** `https://msedge-driver.microsoft.com/LATEST_RELEASE_148_WINDOWS`
- Risk:** Low
- Confidence:** Medium
- Parameter:** `x-content-type-options`
- Attack:** (None listed)
- Evidence:**
 - CWE ID: 693
 - WASC ID: 15
 - Source: Passive (10021 - X-Content-Type-Options Header Missing)
 - Input Vector: (None listed)
- Description:**

The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.
- Other Info:**

This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type.

At "High" threshold this scan rule will not alert on client or server error responses.
- Solution:**

Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages.

If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application/web server to not perform MIME-sniffing.
- Reference:**

<https://learn.microsoft.com/en-us/windows/internet-explorer/compatibility/in622941?view=RS5>

At the bottom of the interface, the 'Current Status' bar shows various icons representing different types of findings and their counts.

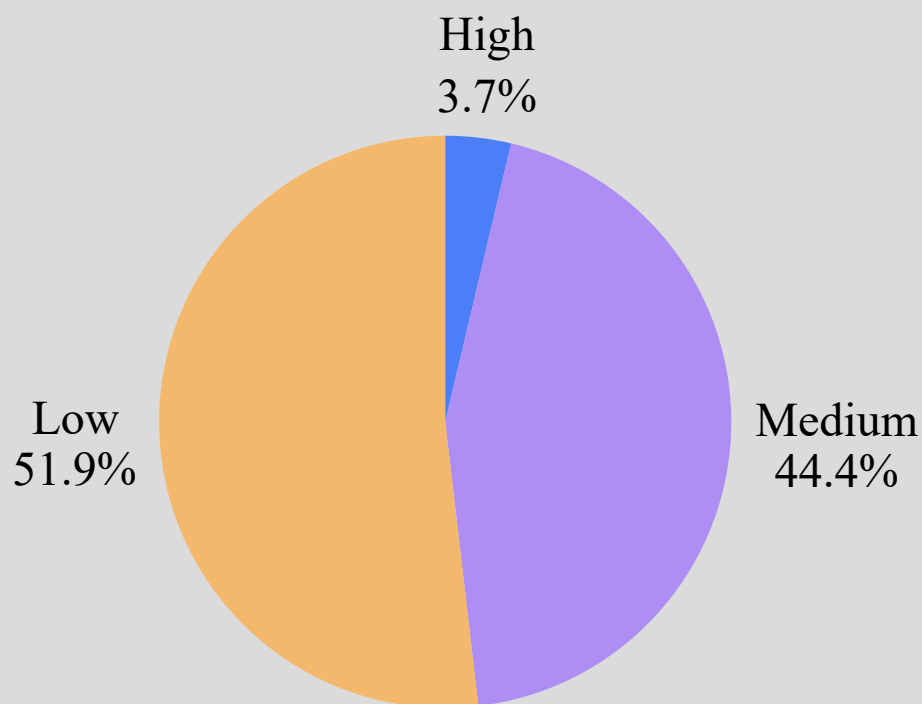
Recommendation

Set:

X-Content-Type-Options: nosniff



Risk Summary



Conclusion

- The assessment identified several medium and low-risk vulnerabilities within the OWASP Juice Shop application.
- Implementing secure cookie configurations and HTTP security headers would significantly improve the application's security posture.